

# Stoquify Supplier Workflow Security Ratification

---

Generated: 2026-08-08 Scope: Supplier workflow, route/action/service path, and dashboard interactions

## Executive security view

The supplier workflow shows a **solid access-control and tenant-boundary posture**:

- Route-level RBAC is enforced before render.
- Module observation calls are present on protected supplier page surfaces.
- Service-layer actions require explicit permission checks and tenant assertion.

No critical breakage was observed in the run.

## Ratification judgment

- **Access-control control plane: Provisional pass**
- **Tenant isolation control plane: Provisional pass**
- **Data minimization / confidentiality for local exports: Needs follow-through**

## Approved controls

- `requirePermission` and `requireAnyPermission` usage on supplier pages/layout is consistent and tested.
- `itemSupplierActions` correctly enforces compound permissions for cross-domain writes.
- `getOrgSuppliers` performs permission check before listing org supplier picker data.
- Service routines protect writes/reads by organization via explicit scoped filters and cross-entity checks.

## Deferred controls (must be implemented before final enterprise sign-off)

### 1. Supplier export redaction policy

- Do not include contact or tax identity fields in default supplier CSV output.
- Restrict sensitive-field export to explicit admin/security intent.

### 2. Auditable export action envelope

- Capture actor, tenant, scope, and fields exported for post-incident traceability.

## Risk note

Given the current state, the workflow is operationally mature and not blocked by RBAC defects, but it is not yet fully enterprise-minimized for data privacy by default. Security ratification should be marked **conditional** until the deferred controls are in place.

## Recommendation

Proceed with P2 remediation first, then rerun the supplier workflow review prompt and refresh security ratification as final.